Τεχνολογικό Πανεπιστήμιο Κύπρου

Τμήμα Μηχανικών Ηλεκτρονικών Υπολογιστών και Πληροφορικής

Έγγραφο Προδιαγραφών Πτυχιακής Εργασίας

Θέμα:

«CoachFlow: Διαδικτυακό Σύστημα Διαχείρισης Προπονητών και Πελατών»

Επιβλέπουσα Καθηγήτρια:
Ελίζα Αγγελίδου Λοΐζου

Φοιτητής:
Αντωνίου Αντρέας
ΑΦΤ: 24892

Περιεχόμενα

0.1 Εισαγωγή 2

0.1.1 Σκοπός 2

0.1.2 Έκταση 2

0.1.3 Ορισμοί 2

0.1.4 Αναφορές 3

0.1.5 Επισκόπηση 3

0.2 Ροή Δεδομένων και Λειτουργίες (Features) 4

0.2.1 Μοντέλα Χρηστών (User Roles) 4

0.2.2 Διαγράμματα Χρήσης (Use Cases) 5

0.2.3 Αρχιτεκτονική Εφαρμογής (Class/Component Diagram) 13

0.3 Entity - Relationship Configuration 15

0.3.1 Στοιχεία Βάσης Δεδομένων 15

0.4 Συναλλαγές και Αποθήκευση Δεδομένων 17

0.4.1 Ενσωμάτωση Πληρωμών (Stripe API) 17

0.4.2 Αποθήκευση Αρχείων (Media Storage) 17

0.4.3 Επικοινωνία μέσω Email (Mailchimp & Gmail SMTP) 17

0.5 Ασφάλεια & Μεταβλητές Sessions (Tokens) 18

0.1 Εισαγωγή

0.1.1 Σκοπός

Ο σκοπός αυτού του εγγράφου προδιαγραφών είναι να παρουσιάσει αναλυτικότερα την λειτουργικότητα της πλατφόρμας "CoachFlow". Το CoachFlow είναι ένα σύγχρονο διαδικτυακό σύστημα που γεφυρώνει προπονητές (coaches) και πελάτες (clients), προσφέροντας εργαλεία για την δημιουργία και παρακολούθηση προγραμμάτων γυμναστικής (workouts), πλάνων διατροφής (nutrition), διαχείριση αγορών και επικοινωνία.

0.1.2 Έκταση

Το έγγραφο καθορίζει τις κύριες λειτουργίες του συστήματος με βάση τις απαιτήσεις των χρηστών (προπονητών και απλών χρηστών) και την αρχιτεκτονική του λογισμικού όπως αυτή έχει σχεδιαστεί και αναπτυχθεί.

0.1.3 Ορισμοί

React.js, Vite, Material-UI, Bootstrap
: Οι κύριες τεχνολογίες που θα χρησιμοποιηθούν για την ανάπτυξη της διεπαφής χρήστη (Frontend). Η χρήση React επιτρέπει τη συντήρηση ενός δυναμικού και γρήγορου Single Page Application (SPA).

PHP, Composer, REST API
: Τεχνολογίες του Backend. Το backend διαχειρίζεται τα αιτήματα των χρηστών, επικοινωνεί με τη βάση δεδομένων και τα εξωτερικά APIs.

MySQL & Firebase
: Η σχεσιακή Βάση Δεδομένων MySQL χρησιμοποιείται για την αποθήκευση των περισσότερων δεδομένων (χρήστες, προγράμματα, αγορές). Το Firebase χρησιμοποιείται για την λειτουργία ταυτοποίησης (Authentication) και συγχρονισμό δεδομένων σε πραγματικό χρόνο όπου απαιτείται.

Stripe API
: Η υπηρεσία που ενσωματώνεται στο σύστημα για την επεξεργασία και ασφάλεια των ηλεκτρονικών πληρωμών (συνδρομές/πακέτα προπονητών).

Mailchimp API
: Υπηρεσία marketing/email audiences που χρησιμοποιείται για εγγραφές χρηστών σε λίστες (audiences) και βασική διαχείριση campaigns όπου απαιτείται από το σύστημα.

Gmail (SMTP) / Email Service
: Υπηρεσία αποστολής transactional emails (π.χ. επιβεβαίωση εγγραφής, reset password, ειδοποιήσεις) μέσω SMTP (Gmail) από το backend.

0.1.4 Αναφορές

Τεχνικές Ιστοσελίδες :

- https://react.dev/ (React Documentation)
- https://mui.com/ (Material-UI)
- https://www.php.net/ (PHP Documentation)
- https://stripe.com/docs/ (Stripe API)
- https://firebase.google.com/ (Firebase Setup & Auth)
- https://mailchimp.com/developer/ (Mailchimp Developer Docs)

0.1.5 Επισκόπηση

- Στην ενότητα 2 θα γίνει παρουσίαση της αρχιτεκτονικής του συστήματος, των λειτουργιών εγγραφής/είσοδου (Authentication) και της ροής δεδομένων.
- Στην ενότητα 3 θα παρουσιαστούν οι κύριες οντότητες της βάσης δεδομένων (ER Diagram).
- Στην ενότητα 4 θα αναλυθεί η λειτουργία των πληρωμών (Purchases & Subscriptions).
- Στην ενότητα 5 θα παρουσιαστεί η ασφάλεια και η διαχείριση συνεδριών (Sessions/Tokens).

0.2 Ροή Δεδομένων και Λειτουργίες (Features)

0.2.1 Μοντέλα Χρηστών (User Roles)

Το σύστημα υποστηρίζει τους ακόλουθους ρόλους:

1. **Επισκέπτης (Guest):** Μπορεί μόνο να εγγραφεί/συνδεθεί ή να επαναφέρει κωδικό πρόσβασης.
2. **Αθλούμενος (Trainee):** Μπορεί να δει προπονητές, να στείλει αίτημα συνεργασίας (hire coach), να λαμβάνει/εκτελεί προγράμματα (Workout & Nutrition) και να επικοινωνεί με τον προπονητή του.
3. **Προπονητής (Trainer):** Μπορεί να διαχειρίζεται το προφίλ του, να αναθέτει προγράμματα στους αθλούμενους του, να παρακολουθεί την πρόοδο τους και να δέχεται πληρωμές.
4. **Διαχειριστής (Admin):** Έχει γενική εποπτεία της πλατφόρμας, των χρηστών και των συναλλαγών (Analytics, System health).

Λειτουργίες ανά ρόλο (Functional Use Cases)

Trainee (Αθλούμενος)

- **Διατροφή:** Αναζήτηση τροφών μέσω USDA βάσης δεδομένων, καταγραφή γευμάτων/τροφών, προβολή ιστορικού και συνοπτικών στοιχείων (daily summaries).
- **Προπόνηση:** Εκκίνηση προπόνησης/προγράμματος, καταγραφή σετ/ασκήσεων, δυνατότητα skip για ασκήσεις ή σετ, προβολή ιστορικού συνεδριών.
- **Σώμα/Μετρήσεις:** Καταγραφή βάρους και βασικών μετρήσεων (π.χ. waist), προβολή προόδου και αναλυτικών (analytics).
- **Προγράμματα:** Δημιουργία/επεξεργασία προσωπικών plans, αγορά plans από trainers, διαχείριση αγορών (π.χ. edit/delete/hide όπου επιτρέπεται).
- **Coach/Trainer σχέση:** Αποστολή αιτήματος συνεργασίας, σύνδεση/αποσύνδεση, ανταλλαγή μηνυμάτων, εκτέλεση προγραμμάτων του trainer.
- **Αξιολογήσεις:** Αξιολόγηση trainer και αξιολόγηση αγορασμένου workout plan.
- **Analytics:** Προβολή στατιστικών και φιλτράρισμα με ημερομηνίες (date ranges).
- **Προφίλ:** Προβολή και αλλαγή στοιχείων προφίλ.

Trainer (Προπονητής)

- **Προφίλ/Overview:** Προβολή επισκόπησης (dashboard), ενημέρωση προφίλ και διαθεσιμότητας.
- **Προγράμματα προς πώληση:** Δημιουργία custom προγραμμάτων (workout plans) για marketplace/πωλήσεις και διαχείριση αυτών.
- **Αιτήματα/Σχέσεις:** Προβολή και αποδοχή αιτημάτων από trainees, τερματισμός σχέσης (disconnect).
- **Διαχείριση trainees:** Ανάθεση προγραμμάτων, ανάθεση υπαρχόντων προγραμμάτων (re-use), παρακολούθηση προόδου/analytics.
- **Διατροφή trainees:** Ορισμός στόχων/πλάνων διατροφής με βάση USDA ή fully custom οδηγίες ανά γεύμα/ημέρα.
- **Μηνύματα:** Επικοινωνία με trainees.

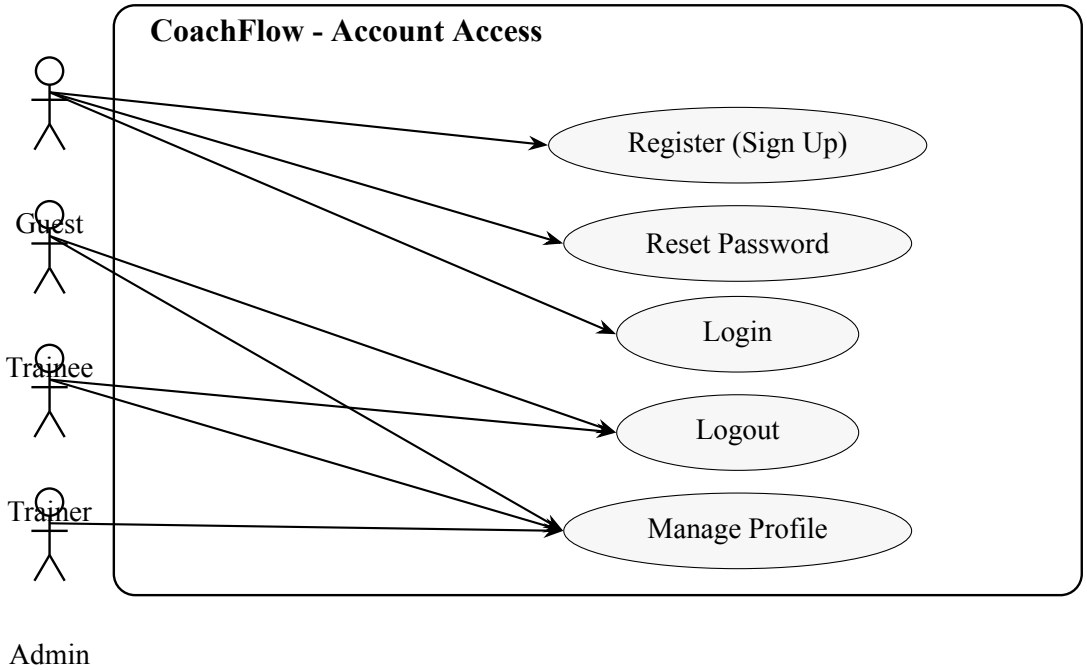
Admin (Διαχειριστής)

- **Platform analytics:** Συνολικά στατιστικά πλατφόρμας (users, purchases, activity).
- **User management:** Προσθήκη/επεξεργασία/διαγραφή, disable/enable, force reset password.
- **Email marketing:** Δημιουργία campaigns (π.χ. μέσω Mailchimp) με custom HTML emails ή templates.
- **Μηνύματα:** Δυνατότητα επικοινωνίας με χρήστες της πλατφόρμας.
- **Προφίλ:** Προβολή και αλλαγή στοιχείων προφίλ.

0.2.2 Διαγράμματα Χρήσης (Use Cases)

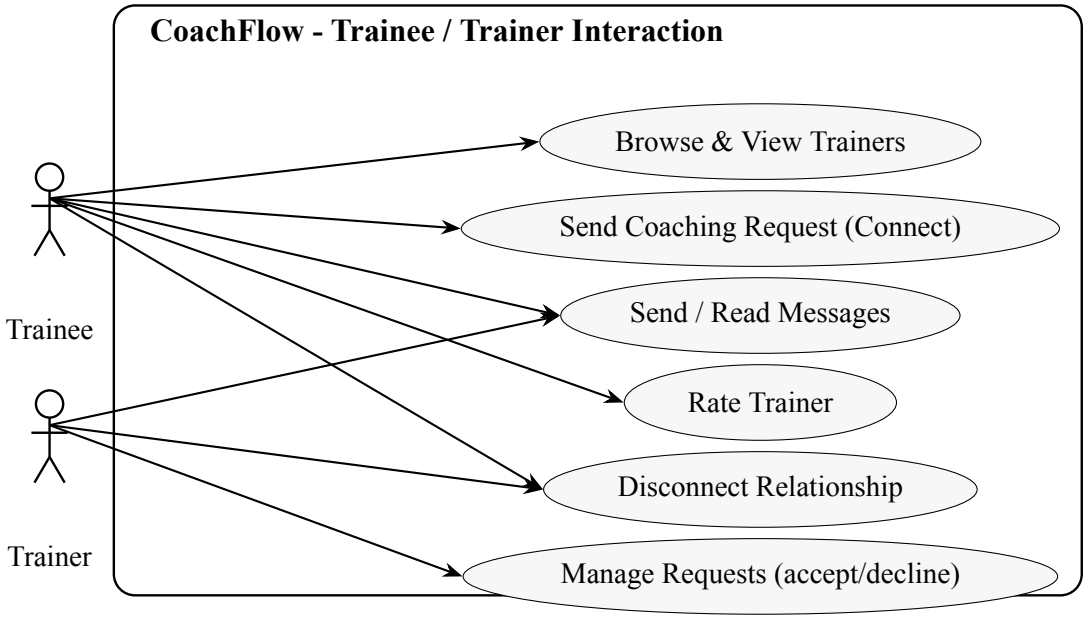
Διαγράμματα Χρήσης (Use Case Diagrams)

1. Account Access



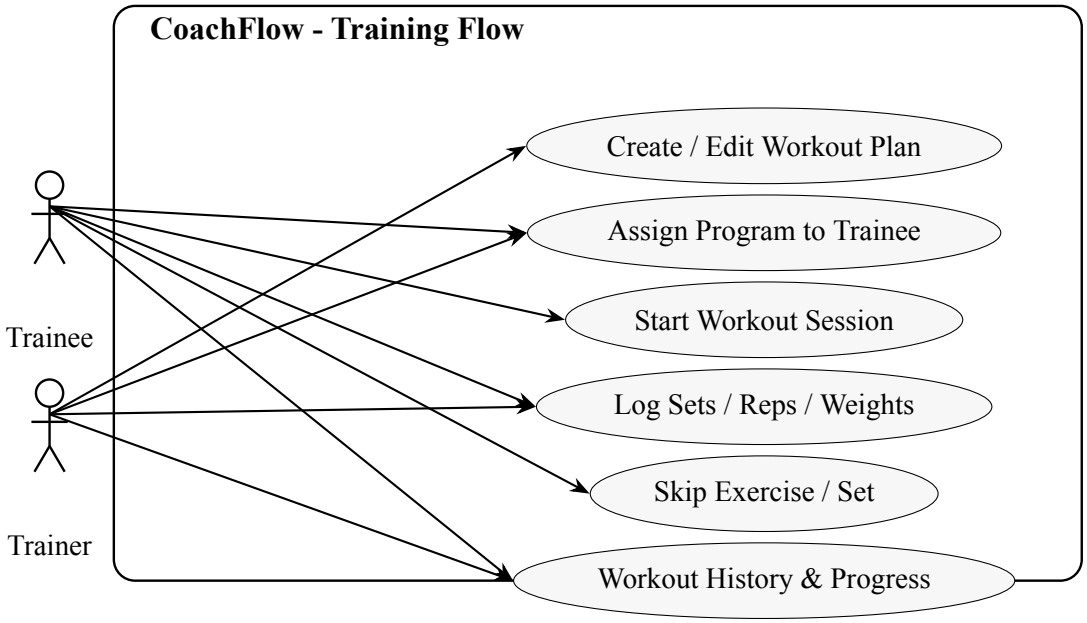
Guest users can only sign up / login / reset password. All other actions require authentication.

2. Trainee-Trainer Interaction



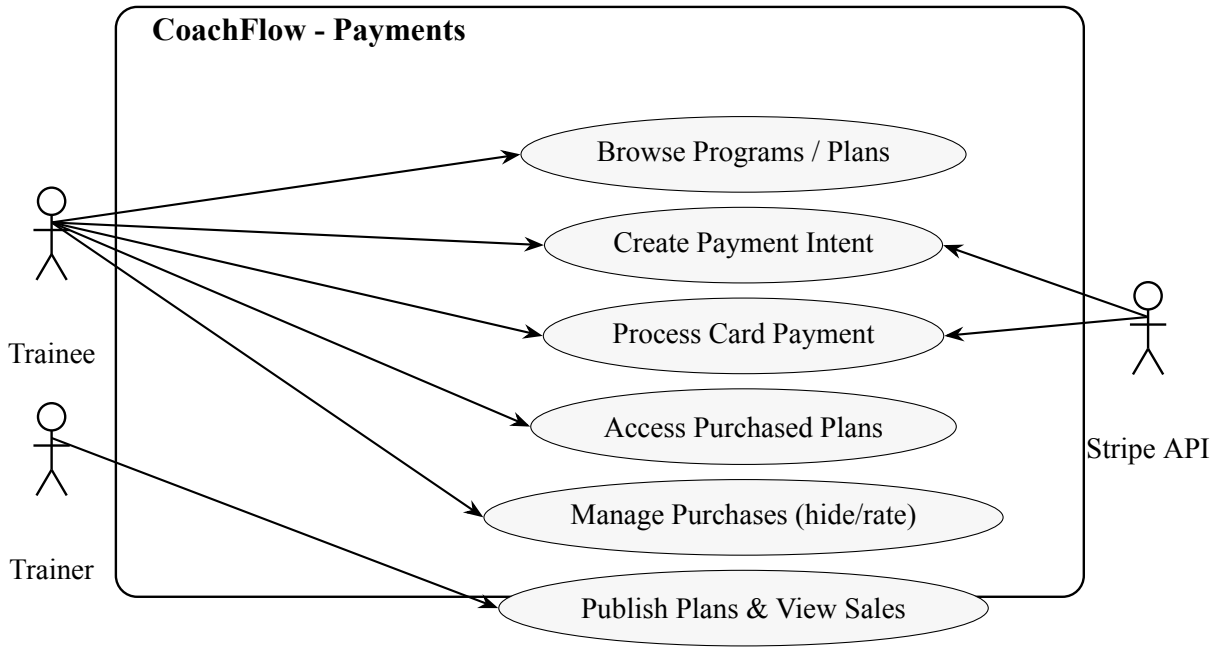
Only authenticated trainees can browse trainers, hire, and message. Guests have no access to these actions.

3. Training Flow



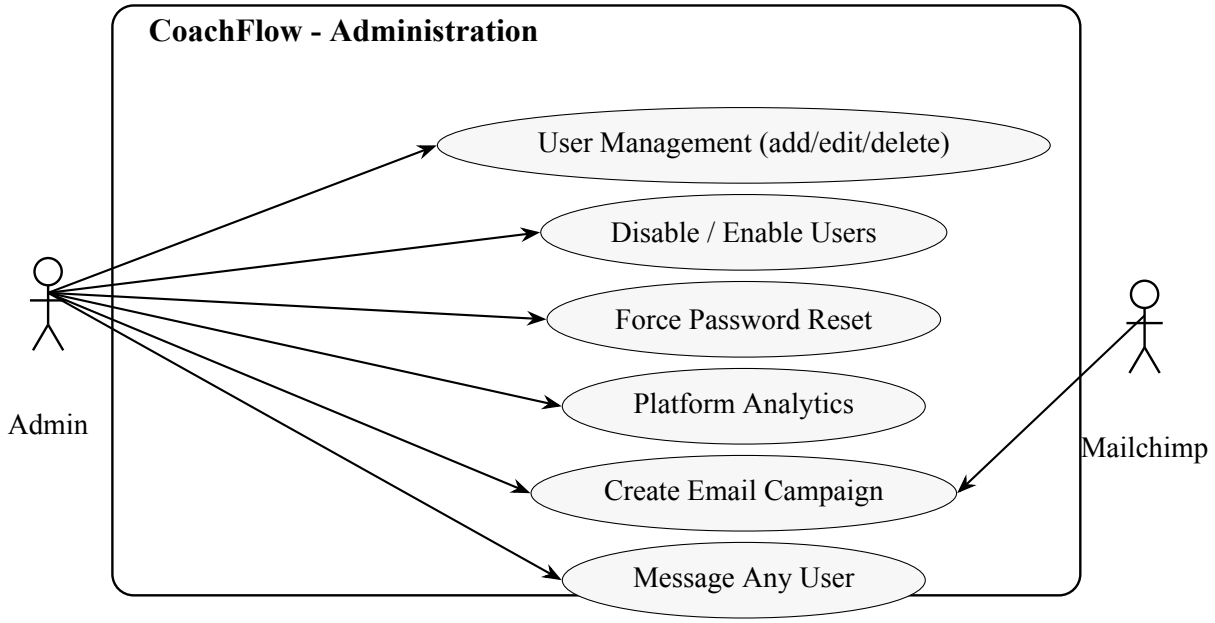
Core training flow: trainers build/assign plans and trainees execute sessions with detailed logging and history.

4. Payments



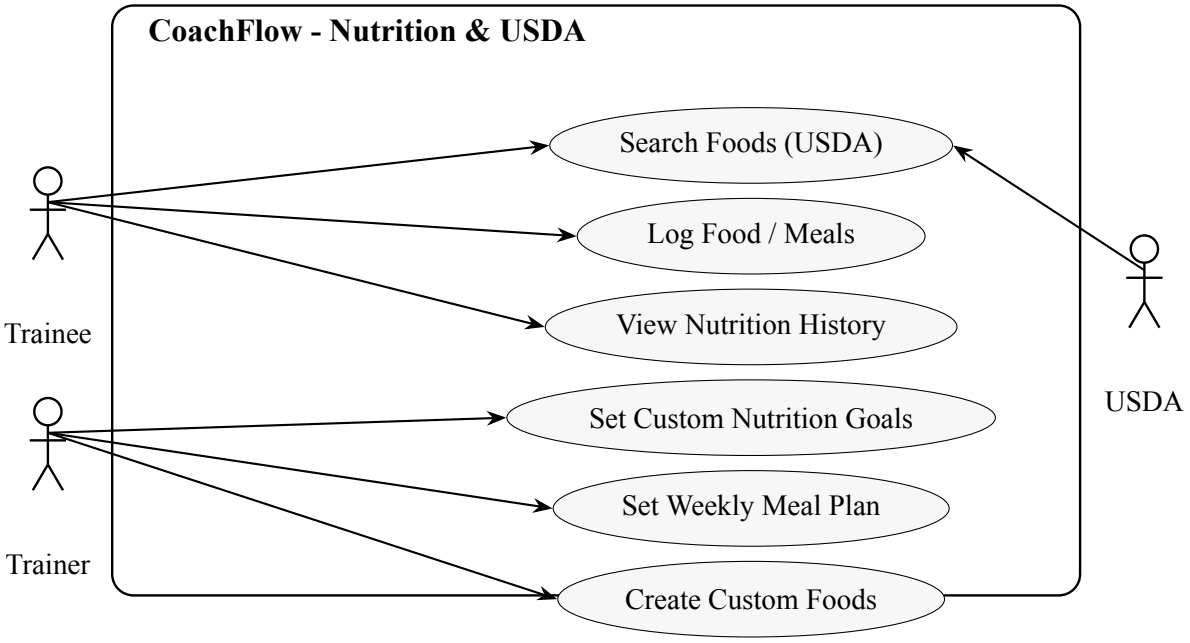
Payments cover plan purchases (trainee) and revenue/sales visibility (trainer) via Stripe.

5. Administration



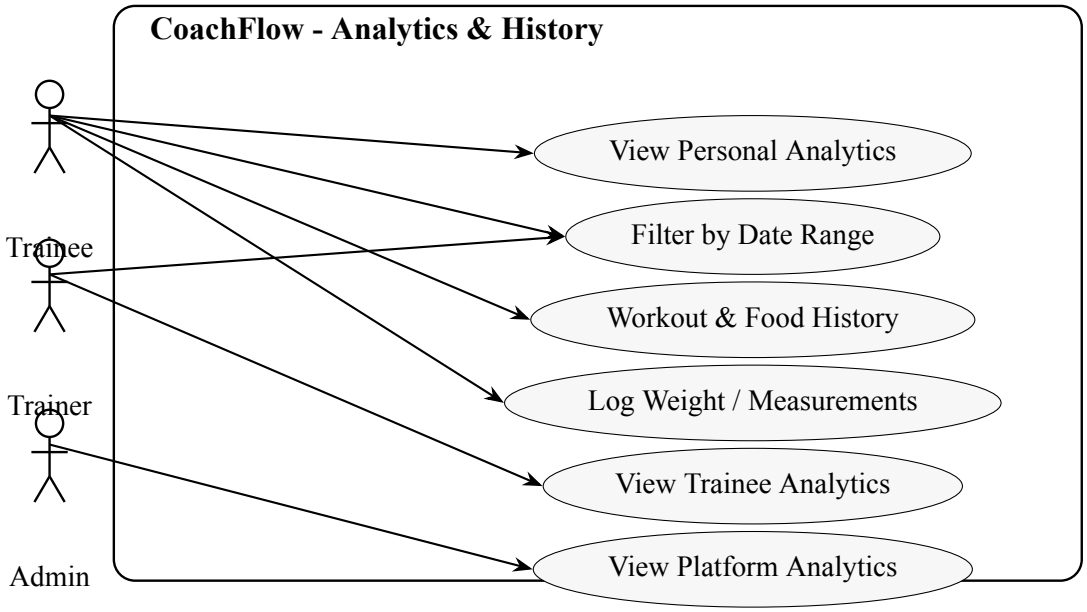
Administration includes platform analytics, full user management, messaging, and email marketing campaigns.

6. Nutrition & USDA



Nutrition includes USDA-based food search plus logging, history, and trainer-assigned goals/meal plans.

7. Analytics & History

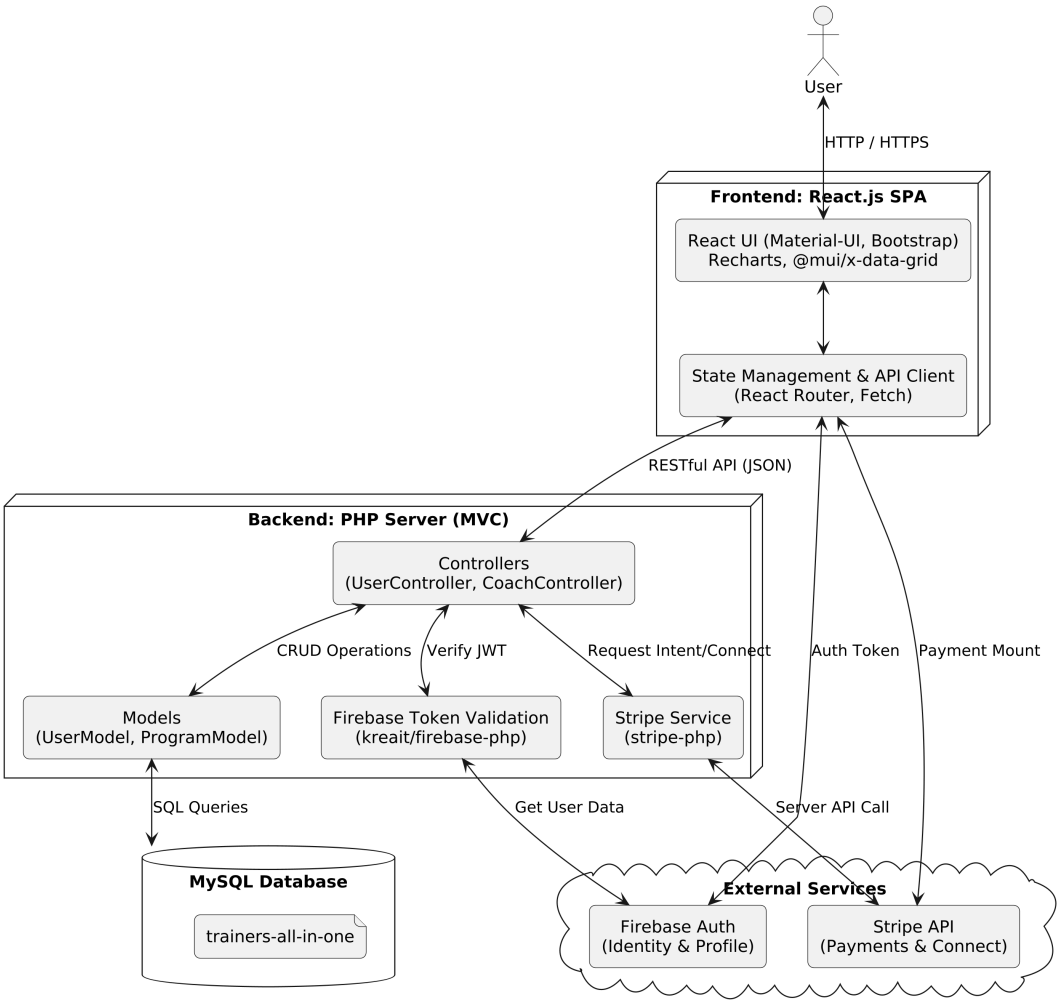


Users can view analytics and history with date filters; trainers see trainee analytics; admins see platform analytics.

Η ταυτοποίηση χρηστών (Authentication) πραγματοποιείται με τη βοήθεια του Firebase Auth, παρέχοντας ένα ασφαλές και κρυπτογραφημένο περιβάλλον. Αφού ο χρήστης ταυτοποιηθεί με επιτυχία στο Firebase, το σύστημα επικοινωνεί με το PHP backend του ελέγχοντας τα στοιχεία από τη MySQL βάση δεδομένων και επιστρέφει το αντίστοιχο προφίλ μαζί με το ρόλο του (Authority/Role).

0.2.3 Αρχιτεκτονική Εφαρμογής (Class/Component Diagram)

Διαχωρισμός Frontend & Backend :



Σχήμα 1: Architecture Diagram: SPA & REST API Μεθοδολογία

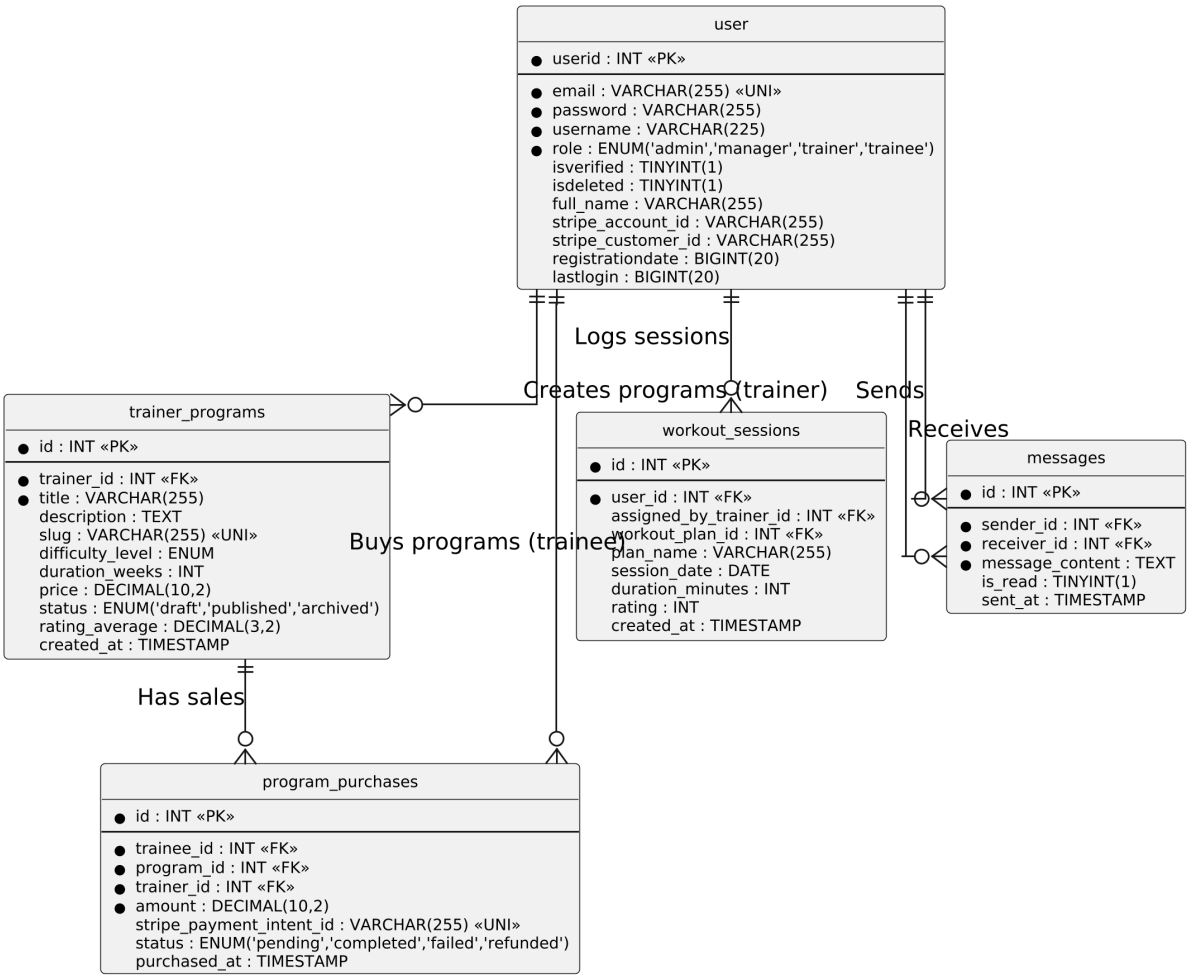
Το σύστημα του CoachFlow ακολουθεί μια πλήρως διαχωρισμένη (decoupled) αρχιτεκτονική, αποτελούμενη από 2 βασικά υποσυστήματα. Το **Frontend Application** (React.js SPA) καταναλώνει πόρους μέσω δομημένων κλήσεων **REST API**, και ο **Backend PHP Server** λειτουργεί ως πάροχος αυτών των υπηρεσιών βασισμένος στο αρχιτεκτονικό πρότυπο Model-View-Controller (MVC).

Η διάδραση και διαχείριση της επιχειρηματικής λογικής χωρίζεται στα εξής επίπεδα:

- **Frontend (React & Vite):** Διαχειρίζεται την κατάσταση (state) και τη διεπαφή του χρήστη με την χρήση βιβλιοθηκών όπως το Material-UI για τα UI components, το Recharts για τα γραφήματα αναλυτικών στοιχείων (Analytics), και το @stripe/react-stripe-js για την ασφαλή εισαγωγή καρτών.
- **Controllers (PHP):** Υποδέχονται τα HTTP Requests της React εφαρμογής και κατευθύνουν τη λογική του backend (π.χ. UserController, CoachController, WorkoutController, NutritionController). Φροντίζουν για το validation των δεδομένων προορίζοντας τα κατάλληλα HTTP Status Codes πίσω στον client.
- **Models (PHP) & MySQL:** Τα Models (όπως UserModel, ProgramModel, PurchaseModel, AnalyticsModel) είναι υπεύθυνα για τις εντολές SQL (Queries) και την ενσωμάτωση των δεδομένων στη σχεσιακή βάση trainers-all-in-one.
- **Εξωτερικά Services & Middlewares:** Το σύστημα ενσωματώνει Firebase Admin SDK (kreait/firebase-php) για ασφαλή ταυτοποίηση χρηστών (JWT Validation) και το Stripe API για τη διαχείριση οικονομικών συναλλαγών (Payments & Payouts).

0.3 Entity - Relationship Configuration

0.3.1 Στοιχεία Βάσης Δεδομένων



Σχήμα 2: Database Schema ER Diagram

Οι κύριοι πίνακες του συστήματος και οι σχέσεις τους έχουν σχεδιαστεί ώστε να καλύπτουν πλήρως τις ανάγκες διαχείρισης:

- **Πίνακας Users & Coaches:** Αποθηκεύει στοιχεία προφίλ, επαφών και το ρόλο του χρήστη. Ένας χρήστης συνδέεται με έναν ή περισσότερους προπονητές (σχέση N προς M ή 1 προς N μέσω ενδιάμεσου πίνακα).
- **Πίνακας Workouts & Nutrition:** Συνδέονται άμεσα με το ID του χρήστη (Foreign Key: User_ID) στον οποίο έχουν ανατεθεί, καθώς και με το ID του προπονητή που τα δημιούργησε.
- **Πίνακας Progress/Analytics:** Κρατάει ιστορικό σωματικών μετρήσεων του χρήστη ανά ημερομηνία, προσφέροντας data για τα διαγράμματα στο Frontend.

* Οι κωδικοί πρόσβασης αποθηκεύονται στη βάση δεδομένων μόνο σε hashed μορφή (π.χ. password_hash()), και δεν αποθηκεύονται ποτέ ως απλό κείμενο.

0.4 Συναλλαγές και Αποθήκευση Δεδομένων

0.4.1 Ενσωμάτωση Πληρωμών (Stripe API)

Για την ενοικίαση υπηρεσιών (Hire a coach), το CoachFlow ενσωματώνει το **Stripe**. Όταν ο πελάτης προχωρά σε αγορά, το σύστημα επικοινωνεί μέσω του backend (CreatePaymentIntent.php) με την πλατφόρμα της Stripe, και επιστρέφει στο Frontend το κατάλληλο client_secret για να ολοκληρωθεί η συναλλαγή με ασφάλεια, χωρίς οι πιστωτικές κάρτες να αποθηκεύονται στη δική μας βάση δεδομένων.

0.4.2 Αποθήκευση Αρχείων (Media Storage)

Εικόνες προφίλ των χρηστών, φωτογραφίες προόδου (Progress Photos) και βίντεο/gifs ασκήσεων ενδέχεται να αποθηκεύονται είτε στον φάκελο του server (/frontend/public/assets) για τα στατικά εικονίδια, είτε σε υπηρεσίες φιλοξενίας όπως το Firebase Storage. Το μέγεθος των αρχείων κατά το ανέβασμα ελέγχεται αυστηρά για να αποφευχθεί η υπερφόρτωση δεδομένων.

0.4.3 Επικοινωνία μέσω Email (Mailchimp & Gmail SMTP)

Το CoachFlow χρησιμοποιεί δύο συμπληρωματικούς μηχανισμούς για emails:

- **Gmail (SMTP):** για transactional emails (signup/verification, reset password, ειδοποιήσεις) που αποστέλλονται από το backend.
- **Mailchimp API:** για διαχείριση audiences/marketing εγγραφών (best-effort), χωρίς να επηρεάζεται η βασική λειτουργία του συστήματος σε περίπτωση προσωρινής αποτυχίας του εξωτερικού service.

Τα κλειδιά πρόσβασης και credentials αποθηκεύονται σε μεταβλητές περιβάλλοντος (.env) και δεν εκτίθενται ποτέ στο frontend.

0.5 Ασφάλεια & Μεταβλητές Sessions (Tokens)

Το σύστημα χρησιμοποιεί **HTTP-only PHP sessions** για την εξουσιοδότηση των κλήσεων στο REST API, σε συνδυασμό με **CSRF protection** και σωστή ρύθμιση **CORS**. Με αυτό τον τρόπο το frontend (React) μπορεί να είναι decoupled, ενώ το backend παραμένει ασφαλές απέναντι σε επιθέσεις τύπου CSRF/XSS.

- Κατά το Login, ο server δημιουργεί session και αποθηκεύει βασικά στοιχεία (π.χ. user_id και ρόλο).
- Σε κάθε κλήση από το frontend, το session cookie αποστέλλεται αυτόματα (με credentials) και το backend ελέγχει τα δικαιώματα μέσω Auth.php (HTTP 401/403 όταν δεν επιτρέπεται πρόσβαση).
- Για αποτροπή CSRF, δημιουργείται token στο session και διατίθεται στο frontend (π.χ. cookie XSRF-TOKEN) ώστε να μπορεί να σταλεί σε headers.

Οι πληροφορίες που χρησιμοποιούνται στο session/State είναι:

- user_id
- username
- user_privileges (trainee / trainer / admin / manager)
- logged_in (boolean flag)
- csrf (server-side CSRF token που συγχρονίζεται και ως cookie XSRF-TOKEN)